

eBPCO

Master Command

A tab-indexed, executable command set taking the Electronic Building Permit and Certificate of Occupancy system from two disconnected front ends to a single production service — a backend of record, a ratified contract, and both the applicant mobile app and the LGU web admin fully integrated against it.

The finding that shapes this entire document. As measured on 19 August 2026, **no backend exists**. The Angular web admin makes zero HTTP calls and runs entirely off an in-memory seed file. The Flutter mobile app ships a client for an *assumed* contract and defaults to mock data. Neither application has ever exchanged a byte with the other. Every command in Phase A exists because of this, and no client work in Phase B can be verified until Phase A stands up.

DOCUMENT

Production Launch Master Command

ISSUED

19 August 2026

STRUCTURE

21 TABs · 3 phases

BASELINE

analyze clean · 443 tests green

STATUS

For execution

Contents

0	Reading this document	B	Phase B — Client integration
1	The Master Command	10	Mobile: complete the live repository layer
2	Where the system actually stands	11	Mobile: secure credential & session storage
3	Regulatory baseline for production	12	Mobile: offline queue & sync
4	Target architecture	13	Admin: replace the in-memory store
5	Standards this programme is held to	C	Phase C — Production hardening
A	Phase A — Contract & backend of record	14	Security hardening & assessment
01	Ratify the API contract	15	Observability, SLOs, incident response
02	Stand up the backend service	16	Performance & capacity
03	Identity, authentication, session	17	Accessibility & localisation
04	Canonical data model & persistence	18	Test strategy & CI/CD
05	Application lifecycle engine	19	Release engineering & store delivery
06	Document service	20	Data privacy compliance (RA 10173)
07	Assessment & payments	21	Go-live: cutover & readiness review
08	Notification & delivery service	D	Dependency map & critical path
09	Audit trail & the RA 11032 clock	E	Decisions the owner must make

0 Reading this document

Each TAB is one self-contained command. A TAB carries the imperative, the reason it exists, a scope table, a concrete technical specification, the standards it is held to, and acceptance criteria that can be checked without asking anybody's opinion. TABs are executed in order within a phase; phases overlap only where the dependency map in section D says they may.

A TAB is complete when its acceptance criteria pass on evidence — a test run, a scan report, a signed decision — not when the work feels done. That distinction is not pedantry: the previous programme recorded five TABs as complete on section-level acceptance while rows of their own scope tables had never been built, and the gap was only found by auditing the tables directly.

Priority and owner tags appear on every TAB:

P0 LAUNCH BLOCKER

P1 REQUIRED FOR PILOT

P2 REQUIRED FOR SCALE

BACKEND

MOBILE

ADMIN

OPS / GOVERNANCE

1 The Master Command

Build and operate one authoritative eBPCO service, and integrate the applicant mobile app and the LGU web admin against it, so that a building permit application submitted on a phone and the officer's decision on it are the same record — to a standard that survives an audit, a penetration test, and the Data Privacy Act.

1.1 Non-negotiables

Rule	Why it is not open for discussion
The server is the record	Lifecycle status, classification, assessed amounts, evaluations, and release records are decided by the backend and never by a client. Two clients each computing their own view of a permit's state is how an applicant and an officer end up disagreeing about whether a permit was issued.
One contract, machine-readable	The OpenAPI document is the single source of truth. Mobile DTOs, admin TypeScript models, and server handlers are all generated from or validated against it. A contract that lives in three hand-written copies has already drifted.
Money is integer centavos, end to end	Already true in mobile (<code>PesoAmount</code>) and admin (<code>assessedAmountCentavos</code>). The wire format and the database must match. A float anywhere in a fee path is a defect, not a rounding preference.
No invented figures, ever	No Order of Payment means no amount is shown and no payment can be started. An estimate on a government fee screen is a misrepresentation.
Unknown enum values are rejected, not defaulted	Mobile's DTO layer already throws on an unrecognised status. Keep it. Silently mapping an unknown server state to a plausible client state is how an applicant is told a rejected permit is under review.
Never assert a pledge the LGU has not made	RA 11032 countdowns must derive from the LGU's published Citizen's Charter. Where charter data is missing, the app says "approximate" or "awaiting classification". Guessing risks falsely accusing the LGU of lateness.
Personal data is minimised and accounted for	Every field collected must map to a lawful basis and a retention period under RA 10173. "We might need it later" is not a basis.
No production action without a runbook	Deploys, migrations, and rollbacks are written down and rehearsed before they are performed on real applicant data.

1.2 Technical constitution

- **Trunk-based development** with short-lived branches; every merge to `main` is releasable.
- **Conventional Commits** and **Semantic Versioning** across all three repositories.
- **Everything as code** — infrastructure, pipelines, database schema, alerts, dashboards.
- **No shared mutable state between services without a migration path.** The in-memory admin store is the thing being removed; do not recreate it server-side as a singleton.
- **Tests are the specification.** A behaviour without a test is a behaviour nobody has agreed to.
- **One clock per feature.** Time is injected, never read from the wall clock inside presentation code — see the 19 August 2026 fix in TAB 18.

2 Where the system actually stands

Measured on 19 August 2026 against the working tree, not against prior completion reports.

2.1 The three tiers

Tier	Technology	State as measured
Applicant mobile eBPC0-Mobile-App	Flutter 3.47 Dart 3.13	357 Dart source files, 51 test files, 443 tests green, analyzer clean . All five original TABs plus cross-cutting work complete. An HTTP client exists for applications only, behind <code>--dart-define=EBPC0_API_BASE_URL</code> ; the default build is entirely mock.
LGU web admin E-BPC0-Software-main	Angular 22 RxJS 7.8	Zero HTTP calls in the entire source tree . No <code>HttpClient</code> , no <code>fetch</code> , no API base URL. State is an in-memory store hydrated from <code>application-seed.ts</code> and lost on refresh. Twelve page modules, a 19-value lifecycle vocabulary, and a permissions model — all of it front-end only.
Backend	—	Does not exist . No repository, no schema, no deployment, no environment.

The integration has never been exercised. Mobile's contract in `lib/core/api/` was written against the admin's published vocabulary, which is the right instinct, but it was authored unilaterally and recorded as an assumption (M-21). Until a server answers those five endpoints, every "integrated" claim is untested. TAB 01 exists to convert that assumption into an agreement before anybody builds to it.

2.2 What the 19 August sweep found and fixed

Finding	Disposition
Two sources of truth for "today" in two features whose entire job is judging dates. <code>professionals_screen</code> and <code>notifications_screen</code> read <code>DateTime.now()</code> directly while their providers carried injectable clocks.	Fixed. Both providers now expose <code>now</code> ; both screens read it. This was not theoretical: the professionals test pinned the clock to 2026-08-18 and asserted "expires in 44 days", the screen ignored the pin and counted from the real date, and the suite began failing the day the date rolled over — and would have failed differently every subsequent day.
Dead widget. <code>quick_action_card.dart</code> unreferenced since the Quick Actions grid was cut from Home.	Removed.
Route reachability. All 66 routes checked for inbound navigation.	Clean. Only <code>/splash</code> is unreferenced, correctly, as the router's initial location.
Orphaned source files. Every file in <code>lib/</code> checked for an inbound import.	Clean after the removal above; only <code>main.dart</code> remains unimported, as the entry point.

2.3 The gaps this programme closes

#	Gap	Severity	Closed by
G1	No backend of record	P0	TABs 02, 04, 05
G2	API contract assumed, never agreed	P0	TAB 01

G3	Admin has no persistence — a browser refresh loses an officer's work	P0	TAB 13
G4	No server-issued session; mobile sends no Authorization header	P0	TABs 03, 11
G5	Session token would be stored in unencrypted SharedPreferences	P0	TAB 11
G6	Android release builds are signed with the debug key	P0	TAB 19
G7	Only applications has a live repository; auth, notifications, business, documents, professionals and payments are mock-only	P0	TAB 10
G8	No CI/CD of any kind in any repository	P1	TAB 18
G9	No crash reporting, no logging, no metrics, no alerting	P1	TAB 15
G10	No offline submission queue; a dropped connection loses a submission	P1	TAB 12
G11	No NPC registration, privacy notice, DPO contact, or retention policy	P0	TAB 20
G12	No document malware scanning on an upload path open to the public	P0	TAB 06
G13	Citizen's Charter data (classifications, pledged days, fee schedules) not supplied	P1	TAB 09 + owner decision E-3
G14	Language picker is display-only; no Filipino localisation	P2	TAB 17
G15	No performance or capacity evidence on target hardware or networks	P1	TAB 16
G16	No independent security assessment	P0	TAB 14

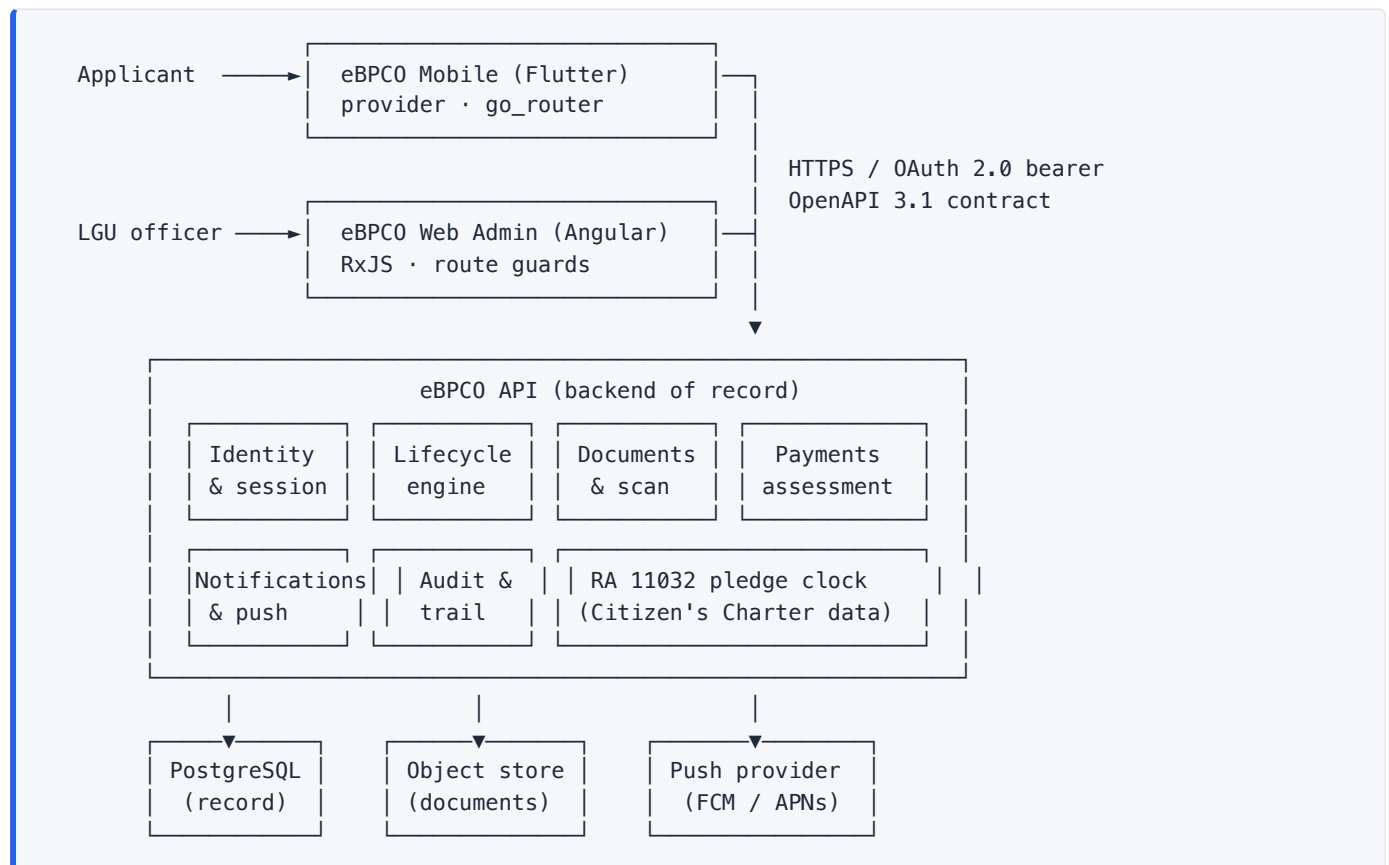
3 Regulatory baseline for production

This is a government service handling personal data and statutory deadlines. These instruments are constraints on the build, not background reading.

Instrument	Binding effect on this programme
PD 1096 National Building Code	Defines the permits themselves, the signing-and-sealing requirement for licensed professionals, and occupancy certification. The permit catalog and wizard field sets answer to it.
RA 11032 Ease of Doing Business and Efficient Government Service Delivery Act, 2018	Prescribed processing periods by transaction classification (simple / complex / highly technical), the Citizen's Charter obligation, and the zero-contact policy. The pledge clock in TAB 09 is a compliance mechanism, not a UX feature. ARTA is the oversight body.
Amended JMC 2021-01 DPWH / DILG / DICT / ARTA	Streamlining of building permit and occupancy issuance, unified application forms, and the mandate for electronic processing. Wizard field sets must be auditable against the unified forms.
RA 9514 Fire Code of the Philippines	Fire Safety Evaluation Clearance sits inside the permit path; the lifecycle must be able to represent an external clearance the LGU does not itself issue.
RA 10173 Data Privacy Act of 2012, its IRR, and NPC issuances	Lawful basis, proportionality, transparency, data subject rights (access, correction, erasure, portability, objection), breach notification within 72 hours, appointment of a Data Protection Officer, and registration of data processing systems. NPC Circular 16-01 sets security requirements specific to government agencies. Governs TABs 03, 04, 06, 11, 14 and 20.
RA 8792 E-Commerce Act of 2000	Legal recognition of electronic documents and signatures — the basis on which an electronically filed application and an electronically issued permit are valid. Drives the integrity and non-repudiation requirements in TAB 09.
RA 11055 Philippine Identification System Act	Relevant if PhilSys is adopted for identity proofing. Note the Act constrains how PhilSys data may be used and retained — adopting it is a decision (E-5), not a default.
BSP regulation of payment channels	Any channel beyond Bank Transfer and Onsite requires the LGU to formally accept it and a regulated provider to process it. Offering an unaccepted channel would strand an applicant's money.

Legal review is a gate, not a review. The privacy notice, retention schedule, terms of service, and any e-signature claim must be reviewed by counsel and by the LGU's Data Protection Officer before the first real applicant record is accepted. This document cannot substitute for that and does not attempt to.

4 Target architecture



4.1 Architectural decisions to record before Phase A begins

Decision	Recommendation	Reasoning
Backend language and framework	NestJS on Node/TypeScript , or Spring Boot if the LGU's IT unit is Java-shopped	NestJS shares TypeScript with the existing Angular admin, so the domain vocabulary in <code>core/domain/*.model.ts</code> can be lifted into shared packages rather than retyped — which is exactly the drift this programme is trying to prevent. Pick for the team that will operate it, not for novelty.
Database	PostgreSQL 16+	Relational integrity is the point: an application, its documents, its assessment and its audit trail must not be able to disagree. Row-level security and strong JSON support cover the flexible fields without giving up constraints.
Document storage	S3-compatible object store , server-side encrypted, private buckets, pre-signed short-lived URLs	Permit attachments are large, numerous, and personal data. They do not belong in the database, and they must never be reachable by an unauthenticated URL.
Hosting	Per DICT Cloud First Policy ; government community cloud or an accredited provider with in-country data residency	Data residency and the LGU's own procurement rules constrain this more than technology does. Confirm with the LGU before designing around any provider.
API style	REST over HTTPS, OpenAPI 3.1	Both clients already assume REST. Mobile's <code>ApiClient</code> exposes <code>getObject</code> / <code>getList</code> / <code>post</code> / <code>patch</code> and nothing that would need reworking.
Auth	OAuth 2.0 / OIDC with short-lived access tokens and rotating refresh tokens	NIST SP 800-63B. Also the only design in which "sign out everywhere" and token revocation are possible at all.

5 Standards this programme is held to

Standard	Applied in
OpenAPI 3.1 + JSON Schema 2020-12	TAB 01 — the contract, and the code generated from it
OWASP ASVS 4.0 (Level 2)	TAB 14 — backend and admin verification baseline
OWASP MASVS + MASTG	TABs 11, 14 — mobile storage, crypto, network, platform interaction
OWASP API Security Top 10 (2023)	TABs 02, 03, 05, 14 — especially BOLA/BFLA, which is the dominant risk in a system where one applicant must never read another's permit
NIST SP 800-63B	TAB 03 — authenticator, session, and credential lifecycle requirements
NIST SP 800-53 / ISO 27001	TABs 14, 15, 21 — control selection and evidence
The Twelve-Factor App	TAB 02 — configuration, backing services, disposability, logs as streams
OpenTelemetry	TAB 15 — traces, metrics, and logs from one instrumentation layer
Google SRE practice (SLI / SLO / error budget)	TABs 15, 16, 21 — what "working" means numerically
DORA metrics	TAB 18 — delivery performance, measured rather than asserted
Consumer-driven contract testing (Pact or equivalent)	TAB 18 — proving the three tiers still agree, per build
WCAG 2.2 Level AA	TAB 17 — and the existing <code>accessibility_test.dart</code> is the seed of its evidence
Semantic Versioning + Conventional Commits	TABs 18, 19 — release identity across three repositories
ISO/IEC 25010	TAB 21 — the quality model the readiness review scores against
SLSA build provenance	TABs 18, 19 — supply-chain integrity for artefacts that will be signed and published

Contract and backend of record

Nothing downstream is verifiable until a server exists and both clients agree on what it says. Phase A produces a ratified contract, a deployed service, an authoritative data model, and the four domain services the clients already assume are there. No Phase B TAB may be marked complete against a mock.

TAB 01 Ratify the API contract

Priority **P0** · Owner **BACKEND** **MOBILE** **ADMIN** · Depends on nothing · Blocks every other TAB

COMMAND

Produce a single, versioned, machine-readable OpenAPI 3.1 description of the eBPCO API, reconciled against the admin's domain vocabulary and the mobile client's existing DTO layer, reviewed and formally accepted by the LGU and both client owners. Generate client and server types from it. Retire every hand-maintained copy of the contract.

WHY THIS IS TAB 01

Mobile already ships a client for five endpoints and a JSON shape it invented. Admin already ships a 19-value lifecycle vocabulary, a payment model in centavos, and document and evaluation models. These two were written to describe the same permits and have never been compared field by field. Building a server against either one, or against a third reading, guarantees an integration failure discovered late — and the loudest failures will be enum mismatches, which mobile is designed to reject loudly rather than absorb.

SCOPE

Deliverable	Detail
Contract repository	A dedicated ebpc-contract repository (or a top-level directory in the backend repo) holding the OpenAPI document, shared JSON Schemas, and example payloads. Versioned with SemVer independently of the services.
Vocabulary reconciliation	A field-by-field table mapping admin's ApplicationRecord , PaymentTransaction , ApplicationDocument , EvaluationRecord , GeneratedPermit , PermitReleaseRecord and AuditEvent onto mobile's models and onto the canonical wire shape. Every divergence resolved in writing.
Lifecycle projection, formalised	The 19 admin states → 7 applicant-visible states mapping moves out of a TypeScript comment (LIFECYCLE_TO_MOBILE_LABEL) and into the contract as a normative table, so both clients project identically.
Endpoint set	Confirm, correct, or replace the five endpoints mobile assumes, and add the ones no client has yet needed. Minimum surface in the specification below.
Generated types	Dart models for mobile, TypeScript models for admin, server types for the backend — all generated in CI from the contract, never edited by hand.
Formal acceptance	Signed acceptance from the LGU's technical representative and both client owners. The contract stops being an assumption at this signature and not before.

MINIMUM ENDPOINT SURFACE

Identity		
POST	/auth/token	password or authorization_code grant
POST	/auth/token/refresh	rotating refresh

POST	/auth/revoke	sign out / sign out everywhere
POST	/auth/register	applicant self-registration
POST	/auth/password/forgot	initiate reset
POST	/auth/password/reset	complete reset
GET	/me	profile of the authenticated applicant
PATCH	/me	correction of own data (RA 10173 right)
POST	/me/export	data portability request
DELETE	/me	erasure request (subject to retention rules)

Applications

GET	/applications	list own; filter, sort, paginate
POST	/applications	submit (Idempotency-Key required)
GET	/applications/{id}	full record incl. timeline, evaluations, instructions, inspection, permit, release
PATCH	/applications/{id}	draft edits only; server rejects otherwise
POST	/applications/{id}/cancel	subject to owner decision E-4
GET	/applications/{id}/timeline	
POST	/applications/{id}/instructions/{letterId}/resubmit	

Documents

POST	/documents	multipart or pre-signed upload init
GET	/documents/{id}	metadata
GET	/documents/{id}/content	short-lived signed redirect
DELETE	/documents/{id}	subject to retention rules

Payments

GET	/applications/{id}/order-of-payment	
POST	/applications/{id}/payments	submit proof (Idempotency-Key required)
GET	/payments	history; filterable; CSV via Accept header

Notifications

GET	/notifications	feed, paginated
POST	/notifications/{id}/read	
POST	/notifications/{id}/resolve	
GET	/notification-preferences	
PUT	/notification-preferences	
POST	/devices	push token registration
DELETE	/devices/{id}	

Reference data

GET	/permit-types	catalog incl. requirements
GET	/citizens-charter	classifications, pledged days, fee schedule
GET	/holidays?year=	non-working days for the pledge clock
GET	/health /ready /version	

CONTRACT RULES THAT MUST BE NORMATIVE, NOT ADVISORY

- **Money.** Every monetary field is an integer of centavos, named with a **Centavos** suffix. Floats are rejected by schema, not coerced.
- **Enums.** Closed enumerations carrying the admin's exact string labels. Clients reject unknown values; the contract therefore treats adding an enum value as a **breaking change** requiring a version bump.
- **Timestamps.** RFC 3339 with explicit offset. The server stores UTC; the Philippines has no DST but the app must not assume a fixed offset in perpetuity.
- **Errors.** RFC 9457 *Problem Details for HTTP APIs* for every non-2xx, with a stable machine-readable **type**. Mobile's **ApiException** maps onto it.
- **Idempotency.** Every non-GET that creates or moves money or state accepts an **Idempotency-Key** and returns the original result on replay. A resubmitted permit application after a dropped connection must not become two applications.
- **Pagination.** Cursor-based, stable under insertion. Offset pagination silently skips records when an officer files something mid-scroll.

- **Concurrency.** `ETag` / `If-Match` on mutable resources, so two officers editing one evaluation produce a 412 rather than a silent overwrite.

ACCEPTANCE CRITERIA

- ☐ The OpenAPI document validates against the 3.1 specification in CI, on every commit.
- ☐ Every field in admin's seven domain models appears in the contract or is explicitly recorded as client-local with a reason.
- ☐ Every endpoint mobile's `ApiClient` calls exists in the contract with a matching shape, or mobile has been changed to match.
- ☐ The 19→7 lifecycle projection is expressed in the contract, and a generated test asserts both clients implement it identically.
- ☐ Mobile Dart DTOs and admin TypeScript models are generated artefacts; a CI job fails if a hand edit diverges from generation output.
- ☐ A published example payload exists for every endpoint and is used as a fixture by all three tiers.
- ☐ Written acceptance recorded from the LGU technical representative and both client owners, closing M-21.

Do not skip the reconciliation table. It is tempting to declare mobile's assumed shape "the contract" because it is already written and already tested. It was authored without the admin in the room, and the admin is the system of record for everything it describes. Reconcile, then ratify.

TAB 02 Stand up the backend service

Priority **P0** · Owner **BACKEND** OPS · Depends on TAB 01 · Blocks TABs 03–09

COMMAND

Create the eBPCO backend repository and deploy a running, observable, secured service skeleton to three environments — development, staging, production — with infrastructure as code, automated deployment, health and readiness endpoints, and the contract served as live documentation. No business logic in this TAB: the deliverable is a service that can be deployed, monitored, rolled back, and trusted.

WHY THIS COMES BEFORE ANY DOMAIN LOGIC

A service that cannot be deployed repeatably cannot be corrected under pressure. Standing up the delivery path first means every subsequent TAB is exercised end to end from its first commit, and the first production deploy is the fiftieth deploy rather than the first.

SCOPE

Deliverable	Detail
Repository and skeleton	Layered structure — transport, application services, domain, persistence — so lifecycle rules never live in controllers. Dependency injection, configuration by environment only, no checked-in secrets.
Twelve-factor configuration	Every environment-varying value from the environment. A secret manager for credentials. The application must be able to start with no local file present but its environment set.
Containerisation	Multi-stage build, non-root runtime user, pinned base image digests, minimal final layer, reproducible builds.
Three environments	Development, staging (production-shaped, synthetic data only), production. Staging never holds real applicant data — that is a privacy control, not a convenience.
Infrastructure as code	Terraform or equivalent for network, database, object storage, secrets, and compute. No console-clicked resources; anything hand-made is invisible to review and unrecoverable in a disaster.
Deployment pipeline	Build → test → scan → deploy to staging → manual gate → deploy to production. Automated rollback on failed health checks.
Baseline hardening	TLS 1.2+ only with modern ciphers, HSTS, security headers, request size limits, timeouts, structured request logging with correlation IDs, and rate limiting at the edge.
Operational endpoints	<code>/health</code> (liveness), <code>/ready</code> (dependency checks), <code>/version</code> (build SHA and semantic version). Contract served at <code>/docs</code> in non-production only.

ACCEPTANCE CRITERIA

- ☐ A commit to `main` reaches staging with no human action beyond review approval.
- ☐ Production deployment requires an explicit, recorded, revocable approval.
- ☐ A deliberately broken build is rejected by the pipeline and never reaches an environment.
- ☐ A failed deployment rolls back automatically and raises an alert.
- ☐ Every environment is reproducible from the IaC definitions into an empty account.
- ☐ No secret appears in the repository, in an image layer, in a log line, or in an error response — verified by an automated scanner in CI.
- ☐ TLS configuration scores at least A on an external scanner; plaintext HTTP is refused, not redirected, for API paths.
- ☐ Container image scanning runs per build and fails on high or critical vulnerabilities with no accepted exception.

TAB 03 Identity, authentication, and session

Priority **P0** · Owner **BACKEND** · Depends on TABs 01, 02 · Blocks TABs 05–13 · Closes M-01, M-22

COMMAND

Implement server-side identity for two distinct populations — applicants and LGU staff — with OAuth 2.0 / OIDC token issuance, rotating refresh tokens, revocation, role and permission enforcement, and account recovery, meeting NIST SP 800-63B. Every API route except the explicitly public ones must be deniable by default.

WHY

Mobile currently authenticates against a local PBKDF2 verifier and sends no **Authorization** header because `LocalStorageService.sessionToken()` returns null. Admin has a session service and route guards with no server behind them. Both are honest placeholders for a thing that does not exist. Until it does, there is no identity, no authorisation, and no way to answer "who changed this permit".

SCOPE

Area	Requirement
Two populations, one mechanism	Applicants self-register and can only ever see their own records. LGU staff are provisioned by an administrator and carry roles. Both authenticate through the same token endpoint with different scopes — one mechanism, so there is one place to get it right.
Credential storage	Argon2id (memory-hard, tuned to the deployment) or PBKDF2-HMAC-SHA256 at a current iteration count, unique salt per credential, pepper in the secret manager. Never reversible, never logged, never returned.
Password policy	Per NIST SP 800-63B: minimum length over composition rules, screening against known-breached password lists, no forced periodic rotation, no knowledge-based questions.
Tokens	Short-lived access token (≤ 15 min) carrying subject, scopes and roles. Refresh token, long-lived, rotating with reuse detection — a replayed refresh token invalidates the whole family and raises a security event.
Revocation	Sign out, sign out everywhere, and administrative revocation, all effective within one access-token lifetime.
Authorisation	Deny by default. Object-level checks on every record access — OWASP API Security's top risk is exactly an applicant reading another applicant's permit by changing an ID. Enforce in the domain layer so no new controller can forget.
Brute-force and enumeration defence	Rate limiting and progressive delay per account and per source. Registration, login and password-reset responses must not reveal whether an account exists.
Account recovery	Single-use, short-expiry, side-channel-delivered reset tokens. Completing a reset revokes all existing sessions.
MFA for staff	TOTP at minimum for any role that can approve, assess, or release a permit. Optional for applicants; mandatory for staff.
Identity proofing	Decision E-5: how an applicant is proven to be who they claim. Options range from email verification to PhilSys. Affects legal weight of a filing under RA 8792.

ACCEPTANCE CRITERIA

- ❑ Every route is denied without a valid token except a documented public allow-list, proven by an automated test that enumerates routes from the contract.
- ❑ An applicant requesting another applicant's application by ID receives 404 — not 403, which confirms existence — and the attempt is recorded as a security event.

- ☐ A staff member without the required permission receives 403 and no partial data.
- ☐ Replaying a rotated refresh token invalidates the family and raises an alert; a test asserts it.
- ☐ Password reset invalidates all sessions; a test asserts an old access token stops working within its stated lifetime.
- ☐ No credential material appears in any log at any level; asserted by a log-scanning test.
- ☐ Timing and response bodies for login and registration are indistinguishable between existing and non-existing accounts.
- ☐ Staff MFA cannot be disabled by the staff member alone.

TAB 04 Canonical data model and persistence

Priority **P0** · Owner **BACKEND** · Depends on TABs 01, 02 · Blocks TABs 05–09

COMMAND

Design and migrate the authoritative relational schema for applicants, businesses, applications, documents, evaluations, assessments, payments, permits, releases, notifications and audit events — with referential integrity, constraints that make the non-negotiables unrepresentable, versioned migrations, and a retention model that satisfies RA 10173 by construction rather than by policy document.

DESIGN RULES

- **Make illegal states unrepresentable.** If a payment cannot exist without an Order of Payment, that is a foreign key and a NOT NULL, not a code comment. If money is centavos, the column is **BIGINT** and there is a CHECK constraint that it is non-negative.
- **The lifecycle is data, and its transitions are constrained.** Status is an enumerated column; a transition table records which moves are legal. An officer cannot jump an application from Submitted to Released because a UI bug allowed it.
- **Every mutation is attributable.** `created_by`, `updated_by`, `created_at`, `updated_at` on every table, non-null, set by the persistence layer rather than by callers.
- **Soft-delete only where the law requires retention;** hard-delete where the law requires erasure. Decide per table, in writing, and enforce it in the schema.
- **No natural keys as primary keys.** Permit numbers change format; UUIDs do not.
- **Personal data is inventoried at the column level,** tagged in the schema, so TAB 20's records of processing can be generated rather than hand-compiled.

SCOPE

Deliverable	Detail
Schema and ERD	Derived from the ratified contract, not invented alongside it. Published as part of the contract repository.
Migration framework	Versioned, forward-only, reviewed, each migration reversible or explicitly documented as not. Applied automatically in the pipeline; never by hand in production.
Seed and fixture data	Reference data (permit types, charter classifications, holidays) seeded reproducibly. Synthetic applicants for staging — never a copy of production.
Encryption	Encryption at rest for the database and object store. Field-level encryption for identity documents and any government-issued identifier, with keys in a managed key service and a documented rotation procedure.
Backup and recovery	Automated backups, encrypted, retention per policy, and — the part usually skipped — a rehearsed restore with a measured recovery time.
Indexing and constraints	Indexes for every query the contract implies. Unique constraints on anything the domain says is unique, including permit numbers.

ACCEPTANCE CRITERIA

- ☐ Migrations run cleanly from empty to current on every pipeline run.
- ☐ A test proves an illegal lifecycle transition is rejected by the database, not merely by the service.
- ☐ A test proves a payment row cannot exist without its Order of Payment.
- ☐ A test proves no monetary column accepts a non-integer or negative value.

- ☐ A restore from backup into a clean environment is performed and timed; the measured recovery time is recorded against the RTO in TAB 21.
- ☐ Every column holding personal data is tagged, and the tag list reconciles with the TAB 20 processing record.
- ☐ No production migration has ever been applied by hand; the pipeline is the only path.

TAB 05 Application lifecycle engine

Priority **P0** · Owner **BACKEND** · Depends on TABs 03, 04 · Blocks TABs 10, 13 · Closes M-02

COMMAND

Implement the 19-state application lifecycle as a server-authoritative state machine with explicit, permission-gated, audited transitions; project it onto the 7 applicant-visible states exactly as the contract defines; and expose submission, revision loops, evaluation, approval, permit generation and release as API operations that no client can bypass.

WHY THE ENGINE BELONGS ON THE SERVER AND NOWHERE ELSE

Both clients currently advance status locally. Mobile's `ApplicationsProvider` calls `advanceStatus`; admin's in-memory store mutates records directly. That is two independent implementations of a regulated process. When they disagree — and they will — there is no tie-breaker. Moving the machine to the server makes the clients displays of a decision rather than participants in it.

SCOPE

Area	Requirement
Transition table	Every legal move, its required permission, its required preconditions, and its side effects, declared as data. Revision Required loops back from Document Verification, Under Evaluation and For Approval rather than sitting in the sequence. Rejected, Cancelled and Expired are terminal exits.
Preconditions as guards	An application cannot reach Assessed without an Order of Payment. It cannot reach Ready for Release without a generated permit. Guards live in the domain, are individually tested, and produce a specific Problem Details error naming the unmet precondition.
The projection	The 19→7 mapping is implemented once, server-side, and returned in the payload. Clients render what they are given. Neither client may recompute it — that is how two vocabularies fork.
Revision loop	Letters of Instruction as first-class records with their own state, an open count the applicant can act on, and a resubmission endpoint that reopens exactly the steps the letter names. Evaluator remarks are stored and returned verbatim ; never summarised, never truncated.
Classification	Server assigns transaction classification from the Citizen's Charter. Where a permit could fall into more than one, the longer classification is taken, so the system never accuses the LGU of lateness it has not incurred. Unclassified applications return no countdown and the clients say "Awaiting classification".
Concurrency	Optimistic locking on the record. Two officers acting simultaneously produce a 412, not a lost update.
Events	Every transition emits a domain event consumed by notifications (TAB 08) and the audit trail (TAB 09). Notifications are never posted by the transport layer.

ACCEPTANCE CRITERIA

- ☐ A table-driven test exercises every legal transition and asserts every illegal one is refused with a specific error.
- ☐ Each transition's permission requirement is asserted independently of its precondition.
- ☐ A test asserts the 19→7 projection matches the contract table for all 19 states.
- ☐ A test asserts no assessment means no amount is returned anywhere in the payload.
- ☐ A test asserts evaluator remarks survive a round trip byte for byte.
- ☐ Concurrent conflicting transitions produce exactly one winner and one 412; asserted under real parallelism.
- ☐ Every transition produces exactly one audit event and the expected notification events, and no duplicates on retry.

TAB 06 Document service

Priority **P0** · Owner **BACKEND** · Depends on TABs 03, 04 · Blocks TABs 10, 13 · Closes G12

COMMAND

Build the document upload, storage, scanning, retrieval and retention service. Every file an applicant submits is validated, scanned for malware, stored encrypted in a private object store, reachable only through short-lived authorised URLs, and subject to a retention rule that is enforced by a job rather than by a promise.

This is the single most exposed surface in the system. An unauthenticated public can upload arbitrary files, which LGU officers then open on government workstations. Without scanning and content validation, the permit portal becomes a malware delivery channel into the LGU network. Nothing in this TAB is optional.

SCOPE

Control	Requirement
Content validation	Allow-list of MIME types (PDF, JPEG, PNG) verified by magic-byte inspection , not by extension and not by the client-supplied content type. Per-file and per-application size caps. Page and dimension limits to stop decompression bombs.
Malware scanning	Every upload scanned before it is retrievable by anyone. Quarantine on detection, notify the applicant that the file was rejected, raise a security event. A file that has not completed scanning is not downloadable.
Storage	Private buckets, server-side encryption, no public ACL possible. Object keys are opaque and non-enumerable. Storage is separate from the record; the database holds metadata and a reference.
Retrieval	Short-lived pre-signed URLs issued only after an authorisation check on the parent application. URLs expire in minutes and are single-purpose. Never a permanent link.
Integrity	SHA-256 recorded at upload and verified on retrieval, so an altered attachment is detectable — a requirement that follows directly from RA 8792's treatment of electronic documents as evidence.
Metadata scrubbing	Strip EXIF from images, including GPS coordinates. An applicant photographing a document at home should not be publishing their home location to the LGU.
Expiry	Document expiry (already modelled in mobile) enforced server-side, so an expired clearance cannot be relied on for a filing.
Retention and erasure	Per-category retention periods (owner decision E-6), enforced by a scheduled job with an audit record of every deletion. Erasure requests honoured within statutory time except where retention law overrides, and the override recorded.

ACCEPTANCE CRITERIA

- ☐ A file whose extension and magic bytes disagree is rejected.
- ☐ A known test malware signature (EICAR) is quarantined, never retrievable, and raises a security event.
- ☐ A file is not downloadable between upload and scan completion; asserted by a test.
- ☐ An expired pre-signed URL returns 403; a URL for another applicant's document is never issued.
- ☐ Uploading an image with GPS EXIF results in stored bytes with no GPS EXIF.
- ☐ Checksum mismatch on retrieval fails closed and alerts.
- ☐ The retention job deletes exactly the eligible objects, records each deletion, and is proven idempotent.
- ☐ Object store is confirmed non-public by an automated configuration check per deploy.

TAB 07 Assessment and payments

Priority **P0** · Owner **BACKEND** · Depends on TABs 04, 05 · Blocks TABs 10, 13

COMMAND

Implement the Order of Payment as the sole authoritative source of any amount owed, with a line-itemised fee schedule, integer-centavo arithmetic end to end, proof-of-payment submission, officer verification, and a reconciliation trail that balances against the LGU's collections.

RULES CARRIED FORWARD, AND NOW ENFORCED SERVER-SIDE

- **No Order of Payment, no amount.** Not zero, not an estimate, not a placeholder. The field is absent and the client cannot start a payment.
- **Money is **BIGINT** centavos everywhere** — wire, service, and column. Totals are computed by summing integer line items; there is no rounding step because there is nothing to round.
- **Submitting proof sets Payment Submitted, never Paid.** Only an officer's verification moves it to Payment Verified. A client must never be able to declare itself paid.
- **Channels are Bank Transfer and Onsite** until the LGU formally accepts others (decision E-7). Offering an unaccepted channel strands an applicant's money.

SCOPE

Deliverable	Detail
Fee schedule	Reference data, versioned and effective-dated, sourced from the LGU's published schedule (M-08). An assessment records which version it was computed under, so a historical Order of Payment can always be explained.
Order of Payment	Line-itemised, each line naming its statutory or ordinance basis. Issued by an officer, immutable once issued; a correction is a new Order superseding the old with a reason, never an edit.
Proof submission	Applicant submits reference number, date, channel, and an attachment routed through TAB 06. Idempotency-keyed so a retried submission does not double-post.
Verification	Officer verifies or rejects with a reason. Rejection returns the applicant to a state that tells them exactly what to do next.
Reconciliation	A report reconciling verified payments against the LGU's collection records, with a documented handling path for discrepancies.
History and export	Payment history filterable and exportable. The current mobile export is clipboard CSV; format and medium are owner decisions M-25/M-26.
Partial and multiple payments	Decide explicitly whether an Order may be settled in parts (decision E-8). If yes, the balance is derived, never stored, so it cannot drift from the sum of its payments.

ACCEPTANCE CRITERIA

- ☐ Property-based tests assert no arithmetic path can produce a non-integer or negative amount.
- ☐ A test asserts an application without an Order of Payment returns no amount field and refuses a payment attempt.
- ☐ A test asserts submitting proof cannot reach Payment Verified without an officer action.
- ☐ A replayed payment submission with the same Idempotency-Key produces exactly one payment record.
- ☐ An issued Order of Payment is immutable; a correction produces a supersession chain with reasons, asserted by test.
- ☐ The sum of an Order's line items equals its total, asserted for every seeded and generated case.
- ☐ A reconciliation report over a synthetic month balances to zero discrepancy.

TAB 08 Notification and delivery service

Priority **P1** · Owner **BACKEND** **MOBILE** · Depends on TABs 05, 03 · Blocks TAB 10

COMMAND

Move notification generation to the server as a consumer of lifecycle events, implement push delivery to registered devices with per-category preferences and quiet hours, and preserve the existing semantics exactly: read and resolved are different things, reading never resolves, muting suppresses the push but never the feed entry, and every application-lifecycle notification is one of the 24 catalog types.

SEMANTICS THAT MUST SURVIVE THE MOVE

These were decided deliberately in the mobile build and are easy to lose when the logic changes tier. They are restated here as requirements on the server, not as history.

- **readAt** and **resolvedAt** are independent. Opening a notification does not discharge the action it describes. The tab badge counts *unresolved actions*, not unread items — an applicant who reads "revision required" and does nothing still owes an action.
- **The catalog is closed.** 24 types. Free-text notifications are not permitted; a new situation earns a new catalog entry and a contract version bump.
- **Muting a category suppresses delivery only.** The feed entry is still recorded, because the LGU must be able to show it told the applicant.
- **Quiet hours are 21:00–07:00.** Suppressed pushes are delivered on the next open window, not dropped.

SCOPE

Deliverable	Detail
Event-driven generation	Notifications are produced by consuming lifecycle domain events, in a transactional outbox so a transition that commits always produces its notification exactly once, and a rolled-back one produces none.
Device registry	Push tokens registered per device per user, with platform, app version and locale. Tokens rotate; stale tokens are pruned on delivery failure.
Delivery	FCM and APNs, with retry and backoff. Delivery outcome recorded per notification so an undelivered critical notice is visible rather than assumed.
Preferences	Server-held per-category preferences, so a reinstall does not silently re-enable everything. NotificationsProvider remains the client's single owner of preference state — SettingsProvider must not keep a second copy.
Escalation channel	Decision E-9: whether SMS or email is used for notices with statutory consequence, since a push to an uninstalled app reaches nobody.
Deep links	Every notification carries a route to the exact screen that resolves it. A notification that cannot be acted on from itself will not be acted on.

ACCEPTANCE CRITERIA

- ☐ A rolled-back transition produces no notification; a committed one produces exactly one, asserted under induced failure.
- ☐ Marking read leaves **resolvedAt** null and the badge count unchanged; asserted by test.
- ☐ A muted category still records a feed entry and sends no push; asserted by test.
- ☐ A push generated inside quiet hours is delivered at the next window, not discarded.
- ☐ Every generated notification's type is a member of the 24-item catalog; a test enumerates and asserts this.

- ❑ Every notification's deep link resolves to a real route in the shipped app.
- ❑ Tests touching quiet hours pin the clock; an unpinned test passes by day and fails at night, and CI runs at all hours.

TAB 09 Audit trail and the RA 11032 clock

Priority **P0** · Owner **BACKEND** **GOVERNANCE** · Depends on TABs 04, 05 · Closes M-12 partially

COMMAND

Implement an append-only audit trail covering every access to and mutation of applicant data, and move the RA 11032 processing-day computation to the server as the authoritative pledge clock — sourced from the LGU's Citizen's Charter and a maintained holiday calendar, with explicit handling for the case where the data is incomplete.

WHY THESE ARE ONE TAB

Both answer the same question from different directions: *can this LGU prove what it did and when*. The audit trail is the evidence; the pledge clock is the measure the evidence is judged against. Building either without the other leaves the LGU able to say only half of what RA 11032 and RA 10173 require it to be able to say.

AUDIT TRAIL

Requirement	Detail
Coverage	Every state transition, every document access, every assessment and payment action, every permission change, every export of personal data, every failed authorisation. Read access to applicant data is auditable — NPC Circular 16-01 expects government agencies to account for who viewed personal data, not only who changed it.
Content	Actor, actor role, action, subject record, before and after where applicable, timestamp with offset, source address, correlation ID, and outcome.
Integrity	Append-only, tamper-evident (hash chaining or write-once storage), retained per policy, and not deletable by application credentials — including administrative ones.
Privacy	The audit trail is itself personal data. It is access-controlled, retained on its own schedule, and never used for a purpose outside accountability.
Usability	An officer can answer "what happened to this application" without a database query. That view is a product feature, not a DBA task.

THE PLEDGE CLOCK

Requirement	Detail
Single implementation	Processing dates are computed in exactly one place server-side, mirroring the discipline already established in mobile's <code>ServicePledgeService</code> . Clients display; they do not compute.
Charter-sourced	Classification and pledged days come from the LGU's published Citizen's Charter (M-08), stored as effective-dated reference data. Nothing is invented.
Holiday calendar	Injectable and maintained. Philippine regular and special non-working days are proclaimed annually; Eidul Fitr and Eidul Adha dates are proclaimed during the year (M-12). Missing data must set an explicit incompleteness flag.
Honest degradation	Where the calendar is incomplete, the computed date is presented as approximate and never asserted. Where classification is unknown, no countdown is produced at all — the client says "Awaiting classification". Under-guessing would falsely accuse the LGU of missing a statutory pledge.
Clock stops	RA 11032 periods exclude time the applicant is responding to a deficiency. The engine must model suspension on Revision Required and resumption on resubmission, and record both.

ACCEPTANCE CRITERIA

- ☐ Every lifecycle transition, document access and personal-data export produces exactly one audit event; asserted by an exhaustive test.
- ☐ An attempt to modify or delete an audit record through any application path fails and raises an alert.
- ☐ A test asserts the pledge clock excludes weekends, calendar holidays, and applicant-response suspension periods.
- ☐ A test asserts an incomplete calendar year yields an approximate flag rather than an asserted date.
- ☐ A test asserts an unclassified application produces no countdown anywhere in the payload.
- ☐ A compliance report over synthetic data reconciles against hand-computed expectations.

Client integration

Both clients stop being self-contained demonstrations and become views onto the service. The rule for this phase: a TAB is complete only when the behaviour is verified against a running backend. Passing against a mock proves the mock, and the mock is the thing being replaced.

TAB 10 Mobile: complete the live repository layer

Priority **P0** · Owner **MOBILE** · Depends on TABs 01–09 · Closes G7

COMMAND

Extend **RepositoryFactory** to build live implementations for every domain — authentication, applications, documents, payments, notifications, business, professionals and profile — so a build configured with a base URL is fully live, and a build without one is fully mock. Eliminate the possibility of a half-live build.

WHY THIS IS ONE TAB AND NOT EIGHT

RepositoryFactory already carries the right idea and says so in its own comment: one place decides what this build talks to, "so a build cannot end up half-live, with applications coming from a server while payments still come from seed data". Today it only implements **applications()**, so that guarantee is currently a comment rather than a fact. Delivering the domains one at a time across releases would create exactly the hybrid state the design exists to prevent.

SCOPE

Deliverable	Detail
HTTP implementations	HttpAuthRepository , HttpDocumentRepository , HttpPaymentsRepository , HttpNotificationsRepository , HttpBusinessRepository , HttpProfessionalsRepository — each against generated DTOs from TAB 01.
Factory completion	Every provider takes its repository from the factory. Providers must stop defaulting to Mock*Repository() in their constructors — that default is what allows a provider to silently go mock inside a live build. Make the repository a required parameter.
Error surface	Problem Details mapped to typed failures, and every screen given a defined behaviour for offline, timeout, unauthorised, forbidden, conflict, and server error. "Something went wrong" is not a defined behaviour.
Loading and staleness	Existing staleness stamping extended to every live surface, so an applicant always knows whether they are looking at fresh data.
Strictness preserved	DTO parsing continues to throw on unknown enum values rather than defaulting. This is a deliberate decision and must not be softened when live data starts arriving; a surprise value is a contract breach and must be loud.
Pagination	Lists consume cursor pagination rather than fetching everything, on the assumption an applicant may accumulate many applications over years.

ACCEPTANCE CRITERIA

- ☐ A test asserts that with a base URL configured, **no Mock*Repository** is instantiated anywhere in the graph — the half-live guarantee proven, not asserted.
- ☐ A test asserts that with no base URL, no HTTP client is constructed and no network call is attempted.
- ☐ Every repository has contract tests running against the generated fixtures from TAB 01.
- ☐ Every screen has a defined, tested rendering for each of the six error classes.

- ❑ An unknown enum value from the server produces a visible, reportable failure — never a silently wrong status.
- ❑ The full journey — register, sign in, create, attach, submit, receive assessment, pay, receive permit — is exercised end to end against a running staging backend.

TAB 11 Mobile: secure credential and session storage

Priority **P0** · Owner **MOBILE** · Depends on TAB 03 · Closes M-01, M-22, G5

COMMAND

Move session tokens out of SharedPreferences into the platform keychain and keystore, implement transparent refresh with rotation, add certificate pinning, and bring the app to OWASP MASVS compliance for storage, cryptography, network and platform interaction.

Today's read point is the wrong storage. `LocalStorageService.sessionToken()` reads SharedPreferences, which is unencrypted on both platforms and readable on a rooted or jailbroken device and in some backup paths. It returns null today, so nothing is currently exposed — which means this must be fixed *before* TAB 03 starts issuing real tokens, not after.

SCOPE

Deliverable	Detail
Secure storage	iOS Keychain with an appropriate accessibility class and no iCloud sync for tokens; Android Keystore-backed encryption via EncryptedSharedPreferences. Tokens excluded from device backups.
Session lifecycle	Transparent refresh on 401 with a single-flight guard so ten concurrent requests produce one refresh, not ten. Refresh failure signs the user out cleanly, clears state, and routes to login with an explanation.
Certificate pinning	Pin to the API's certificate chain with a documented rotation plan and a backup pin, so a certificate renewal does not brick every installed app. Include a kill switch.
Local data at rest	Review everything cached on device. Applicant records, documents and drafts are personal data; decide per category whether it is cached at all, and encrypt what is.
Sign-out completeness	Sign-out clears tokens, caches, cached documents, and in-memory provider state; and revokes server-side. A subsequent launch must show nothing of the previous user.
Screen protection	Consider <code>FLAG_SECURE</code> on screens showing identity documents and permits, and hide sensitive content in the app switcher snapshot.
PBKDF2 retirement	Once the server authenticates, the local <code>CredentialVerifier</code> ceases to be an authentication mechanism. Keep it only if it backs a local unlock feature; otherwise remove it, along with M-17.

ACCEPTANCE CRITERIA

- ☐ A test asserts no token, credential or personal identifier is present in SharedPreferences after sign-in — extending the existing password-storage test to the session.
- ☐ Ten simultaneous 401s produce exactly one refresh call; asserted by test.
- ☐ A refresh failure signs out and clears all local state; asserted by test.
- ☐ A connection presenting an unpinned certificate is refused.
- ☐ Certificate rotation is rehearsed against staging without an app update.
- ☐ Sign-out leaves no cached document on the filesystem; asserted by test.
- ☐ MASVS storage, crypto, network and platform requirements assessed with results recorded in TAB 14.

TAB 12 Mobile: offline queue and sync

Priority **P1** · Owner **MOBILE** · Depends on TABs 10, 11 · Closes M-20, G10

COMMAND

Implement a durable offline submission queue with idempotent replay, conflict handling, and honest status reporting, so an applicant on an intermittent connection never loses a completed application and is never told something was filed when it was not.

WHY THIS IS NOT A NICE-TO-HAVE

A permit application is fifteen or more screens of work and a stack of photographed documents. Losing one to a dropped connection is not a minor inconvenience — it is the kind of failure that sends the applicant back to the counter and defeats the purpose of the system. Mobile connectivity in the target environment cannot be assumed.

SCOPE

Deliverable	Detail
Durable queue	Persisted to disk, surviving app termination and device restart. Encrypted, since queued items contain personal data.
Idempotent replay	Each queued operation carries a client-generated Idempotency-Key created once at enqueue and reused on every retry, so a replay after an ambiguous failure cannot create a second application.
Ordering	Operations on one application replay in order. Document uploads complete before the submission that references them.
Backoff	Exponential backoff with jitter, and a cap. Trigger on connectivity restoration rather than polling, to protect battery.
Honest status	A queued submission is shown as Queued , never as Submitted. The distinction is the whole point: an applicant must not believe a deadline was met when nothing reached the LGU.
Conflict and failure	Permanent failures (validation, authorisation, contract) leave the item in a recoverable state with a plain explanation and a route to fix it. Nothing is discarded silently.
Bounds	Queue size and age limits, with a clear user-facing consequence when reached, so an abandoned queue cannot fill a device.

ACCEPTANCE CRITERIA

- ☐ A submission made offline survives force-quit and device restart and completes on reconnection; asserted by an integration test.
- ☐ A submission interrupted after the server committed but before the response arrived produces exactly one application on replay.
- ☐ A queued item is never displayed with a submitted status; asserted by widget test.
- ☐ A permanently failing item surfaces a specific, actionable message and is never silently dropped.
- ☐ Queue contents are encrypted at rest; asserted by inspecting stored bytes.
- ☐ Replay order is preserved across a mixed queue of uploads and submissions.

TAB 13 Admin: replace the in-memory store

Priority **P0** · Owner **ADMIN** · Depends on TABs 01–09 · Closes G3

COMMAND

Replace the Angular admin's in-memory `application-store` and seed data with the live API across all twelve page modules; wire the session service and route guards to server-issued tokens and server-enforced permissions; and remove the seed file from the production build entirely.

The admin currently loses an officer's work on a browser refresh. There is no persistence of any kind — `application-seed.ts` is rehydrated on every load. An officer who evaluates ten applications and refreshes has evaluated nothing. This is a data-loss defect in the tier that holds the authoritative decisions, and it is the single most urgent item in the admin repository.

SCOPE

Deliverable	Detail
Data access layer	Typed Angular services over <code>HttpClient</code> , using models generated from the contract. An HTTP interceptor attaches the bearer token, handles 401 refresh, and maps Problem Details to typed errors.
Store rewrite	<code>application-store</code> becomes a cache over the API with explicit loading, error and stale states — not a source of truth. Its existing spec suite is the regression net; keep and extend it.
Migration-bridge fields	<code>type</code> and <code>status</code> are denormalised projections maintained by store mutations. With the server authoritative, either the server returns them or the templates are migrated off them. Do not leave a client recomputing a projection the contract defines.
Session and guards	<code>session.service</code> holds server-issued tokens; <code>auth.guard</code> and <code>permissions</code> reflect server-returned roles. Client-side permission checks become a UX affordance only — the server is the enforcement point, always.
Optimistic concurrency	Handle 412 conflicts with a rendered "this record changed" resolution path rather than an overwrite or a silent failure.
Seed removal	<code>application-seed.ts</code> excluded from the production bundle. A build-time check fails if it is reachable from a production entry point.
Officer-critical UX	Long lists paginate server-side; evaluations and Letters of Instruction autosave as drafts, because an officer typing detailed remarks must never lose them to a session timeout.

ACCEPTANCE CRITERIA

- ☐ A browser refresh after an officer action shows the action persisted; asserted by an end-to-end test.
- ☐ No component imports the seed file in a production build; asserted by a build-time check.
- ☐ Every page module reads from the API, with loading, empty and error states rendered and tested.
- ☐ An expired session redirects to login without losing unsaved work, and returns the officer to where they were.
- ☐ A permission the server denies is not merely hidden in the UI — a direct request is refused; asserted by test.
- ☐ Two officers editing one record produce a conflict dialog, not a lost update.
- ☐ An applicant-submitted application appears in the admin queue, and the officer's decision appears in the mobile app — the full loop, demonstrated.

Production hardening and launch

The system works; this phase establishes that it will keep working, that it can be operated, that it is lawful, and that a failure is survivable. TABs 14, 18 and 20 should start during Phase A rather than after it — security, testing and privacy are cheaper designed in than retrofitted.

TAB 14 Security hardening and assessment

Priority **P0** · Owner **BACKEND** **MOBILE** **ADMIN** · Start during Phase A · Closes G16

COMMAND

Bring all three tiers to OWASP ASVS Level 2 and OWASP MASVS, embed automated security testing in every pipeline, and commission an independent penetration test whose high and critical findings are closed and retested before go-live.

SCOPE

Area	Requirement
Threat model	STRIDE or equivalent over the whole system, revisited when architecture changes. Explicitly model the malicious applicant, the compromised officer account, and the malicious upload — these are the realistic adversaries, not an abstract attacker.
API Top 10	Systematic verification against OWASP API Security Top 10 (2023), with broken object-level and function-level authorisation given the most attention. In a permit system, an applicant reading or altering another's application is the worst plausible outcome short of data exfiltration.
Input handling	Schema validation at the edge from the contract. Parameterised queries only. Output encoding in both clients. Strict CSP on the admin.
Dependency and supply chain	SCA on every build across all three repositories, SBOM per release, pinned and verified dependencies, SLSA build provenance. Note the mobile repo currently carries 21 packages behind their latest versions — a policy for currency is part of this TAB.
Static and dynamic analysis	SAST and secret scanning in CI; DAST against staging on a schedule; container and IaC scanning.
Mobile-specific	MASVS verification: no sensitive data in logs, screenshots, or backups; anti-tampering appropriate to the risk; no debug or verbose logging in release builds; obfuscation where it does not impede crash triage.
Independent test	External penetration test of API, admin, and mobile against production-shaped staging. Findings tracked to closure with retest evidence. Not a formality: no P0 or P1 finding may be open at go-live.
Vulnerability disclosure	A published route for reporting a vulnerability, and a policy for triage and response. A government service without one gets its disclosures on social media instead.

ACCEPTANCE CRITERIA

- ☐ ASVS L2 verification recorded with evidence per requirement, and every non-applicable item justified.
- ☐ MASVS verification recorded for the mobile app.
- ☐ SAST, SCA, secret scanning, container and IaC scanning all run per build and fail on high or critical findings.
- ☐ An SBOM is produced and archived for every release artefact.
- ☐ Independent penetration test completed; all high and critical findings closed and retested.

- ☐ An automated authorisation test suite attempts cross-tenant access on every object-scoped endpoint and is refused every time.
- ☐ A vulnerability disclosure policy is published with a monitored contact.

TAB 15 Observability, SLOs, and incident response

Priority **P1** · Owner **BACKEND** **OPS** · Depends on TAB 02 · Closes G9

COMMAND

Instrument all three tiers with OpenTelemetry, define service level objectives with error budgets, build the dashboards and alerts that make a degradation visible before an applicant reports it, and establish an on-call and incident response process including the 72-hour breach notification path RA 10173 requires.

SCOPE

Area	Requirement
Instrumentation	OpenTelemetry traces, metrics and logs. Correlation IDs propagated from client through to database. Structured JSON logs with no personal data and no credentials — enforced by a redaction layer and an automated log-content test, not by reviewer diligence.
Crash and error reporting	Mobile crash reporting with symbol upload per release. Admin front-end error reporting. Both with an opt-in consent path, since crash payloads can carry personal data.
SLIs and SLOs	Availability, latency (p50/p95/p99), and error rate per critical journey — sign-in, list applications, submit application, upload document, submit payment. Numeric targets with error budgets, agreed with the LGU.
Business telemetry	Submissions, approvals, rejections, average processing days by classification, pledge-compliance rate. The LGU needs these for ARTA reporting; deriving them from logs later is far harder than emitting them now.
Alerting	Alert on symptoms (error budget burn, journey failure), not causes (CPU). Every alert has a runbook link and a named owner. Alerts nobody acts on are deleted.
Incident response	Severity definitions, on-call rota, escalation, communication templates for applicants and the LGU, and blameless post-incident review with tracked actions.
Breach response	A specific, rehearsed procedure for personal data breach: containment, assessment, and notification to the National Privacy Commission and affected data subjects within 72 hours of knowledge.

ACCEPTANCE CRITERIA

- ☐ A single request is traceable end to end from client action to database query.
- ☐ An automated test asserts no personal data or credential appears in any log stream at any level.
- ☐ Every critical journey has a published SLO and a dashboard showing error budget consumption.
- ☐ A synthetically induced failure fires the expected alert within its stated detection window.
- ☐ Every alert links to a runbook that has been followed at least once in a drill.
- ☐ A breach notification drill is completed end to end within the 72-hour window and the timings recorded.
- ☐ Crash reports from a release build symbolicate to source.

TAB 16 Performance and capacity

Priority **P1** · Owner **BACKEND** **MOBILE** · Depends on TABs 10, 13, 15 · Closes M-18, G15

COMMAND

Establish performance budgets, load-test the API to and beyond expected peak, profile the mobile app on representative mid-range Android hardware over a throttled connection, and size the infrastructure against measured evidence rather than estimate.

WHY THE DEVICE AND NETWORK MATTER MORE THAN THE SERVER HERE

The app was built and previewed largely on desktop Chrome at 1.0× scale on a fast connection. That environment hides precisely the failures this audience will hit — which is why the app already clamps text scaling to 1.3× after "fine on browser, broken on Android" overflow, and why wizard forms are tested at a 400dp viewport. Those were the right instincts; this TAB converts them into measurement on real hardware.

SCOPE

Area	Requirement
Load profile	Model realistic peak. Permit filing is seasonal and deadline-driven — renewal periods and fiscal year boundaries produce spikes far above the mean. Size for the spike.
API load testing	Sustained load at expected peak, spike tests at multiples of it, soak tests for leaks, and stress tests to find the breaking point and confirm it degrades gracefully rather than collapsing.
Document path	Concurrent large uploads over slow connections — the heaviest and most failure-prone path in the system. Include scanning throughput; the scanner is a bottleneck that will not appear in an endpoint benchmark.
Database	Query analysis under load, index verification, connection pool sizing, slow query alerting.
Mobile profiling	Cold and warm start, frame rendering through the wizards and long lists, memory under document capture, battery over a realistic session, and install size. On a physical mid-range Android device on a throttled network (M-18).
Budgets	Numeric budgets enforced in CI: install size, cold start, p95 journey latency. A regression fails the build rather than being noticed a quarter later.
Capacity plan	Documented sizing with headroom, autoscaling policy, and cost model at expected and peak load.

ACCEPTANCE CRITERIA

- ☐ API sustains modelled peak within SLO for a sustained soak with no memory or connection leak.
- ☐ Beyond breaking point the system sheds load and returns correct errors rather than corrupting data.
- ☐ Concurrent large uploads on a throttled connection complete or fail cleanly and resumably.
- ☐ Mobile cold start, frame timings, memory and battery measured on target hardware and recorded against budgets.
- ☐ Performance budgets enforced in CI, with a deliberate regression proven to fail the build.
- ☐ Capacity plan and cost model reviewed and accepted by the LGU.

TAB 17 Accessibility and localisation

Priority **P1** · Owner **MOBILE** **ADMIN** · Closes M-13, M-19, G14

COMMAND

Bring both clients to WCAG 2.2 Level AA, complete Filipino localisation or reduce the language picker to what is genuinely supported, and verify with assistive technology on real devices — not only in widget tests.

A public service cannot be optional about this. RA 11032 obliges government services to be accessible to the public they serve. A permit portal only some citizens can operate has not delivered the service; it has moved the queue.

SCOPE

Area	Requirement
Existing foundation	<code>accessibility_test.dart</code> already guards 200% text scale, 48dp targets and screen-reader labels, and correctly applies <code>AppTheme.lightTheme</code> rather than Material defaults. Extend its coverage to every screen; it is the right test in the right shape.
Text scaling	The app clamps to 1.3× because layouts were built at 1.0×. That is a pragmatic mitigation, not an accessible outcome — a user who needs 200% is being denied it. Rework the layouts that cannot hold larger text and raise the clamp.
Contrast	Audit against WCAG AA on rendered output (M-19). Where the brand palette fails, that is a brand decision to escalate, not a code fix to improvise.
Assistive technology	Manual testing with TalkBack and VoiceOver through the complete filing journey. Traversal order, focus management on navigation and dialogs, and announcements for asynchronous state changes.
Forms	Every field programmatically labelled; errors associated with their field and announced; the 16 wizards navigable and completable entirely by screen reader.
Localisation	Decision E-10. Either implement Filipino properly — extraction, translation, plurals, dates, currency, and layout that survives longer strings — or reduce the picker to English only. A language picker that changes nothing is worse than no picker , because it promises the service in a language the user is then denied.
Admin accessibility	The same standard applies. LGU staff use this all day, and staff include people who use assistive technology.

ACCEPTANCE CRITERIA

- ☐ Automated accessibility checks cover every screen in both clients and run in CI.
- ☐ The complete filing journey is completed end to end using only TalkBack, and again using only VoiceOver, by a tester who did not build it.
- ☐ Contrast audit passes AA on rendered output, or every failure is escalated as a recorded brand decision.
- ☐ Text scale is supported to the platform maximum on every screen, or each exception is individually justified.
- ☐ Localisation is either complete for the offered languages or the picker offers only what is complete.
- ☐ No untranslated string appears in a shipped locale; asserted by a resource-completeness test.

TAB 18 Test strategy and CI/CD

Priority **P1** · Owner **BACKEND** **MOBILE** **ADMIN** · Start during Phase A · Closes G8

COMMAND

Establish continuous integration for all three repositories, add consumer-driven contract testing between the tiers, build an end-to-end suite over the critical journeys, and enforce the quality gates that make "it passed" mean something.

There is no CI in any repository today. The mobile app's 443 tests and clean analyzer are real and valuable, but they are run by hand. That is why a time-dependent test could sit broken until someone happened to run the suite — and why nothing catches an admin change that breaks the contract. CI is the mechanism that turns a good test suite into a guarantee.

TEST STRATEGY

Layer	Coverage
Unit	Domain logic, state machines, money arithmetic, the pledge clock. Fast, deterministic, no I/O. Property-based tests for arithmetic and date computation, where example-based tests systematically miss edge cases.
Contract	Consumer-driven contracts (Pact or equivalent) between each client and the API. Provider verification runs in the backend pipeline, so a breaking server change fails before it reaches a client — the single highest-value test type in a three-tier system with two independent client teams.
Integration	Backend against a real database and object store in containers. No mocked persistence: the constraints in TAB 04 are part of the behaviour under test.
Widget / component	Mobile widget tests (extend the existing 443) and Angular component tests. Forms tested at a 400dp viewport — a wider window hides real overflows, which is how a missing isExpanded on the discipline dropdown nearly shipped.
End-to-end	The full loop across both clients and the API: register → create → attach → submit → officer evaluates → assessment issued → applicant pays → officer verifies → permit generated → released. Run against staging per release.
Non-functional	Accessibility, performance budgets, and security scanning as pipeline gates, not as periodic projects.

DETERMINISM RULES, LEARNED HERE

- **Pin the clock in any test whose outcome depends on a date.** On 19 August 2026 the mobile suite failed because **professionals_screen** read the wall clock while its test pinned the provider's, so an assertion of "expires in 44 days" decayed by one day, every day. The screens now read the provider's clock and the test is the regression guard.
- **Run CI at varied times of day, or pin the clock.** Quiet hours are 21:00–07:00; an unpinned notification test passes in the morning and fails at night.
- **Add an architecture test that fails on `DateTime.now()` in presentation code.** The two defects found by this sweep were the same defect twice; a lint is cheaper than finding it a third time.
- **No sleeps, no network, no shared mutable fixtures.** A flaky test that is retried is a test nobody believes.

PIPELINE GATES

every pull request	format · analyze/lint · unit · widget/component · contract (consumer) · SAST · secret scan · SCA
merge to main	all of the above · integration · contract (provider) · build artefacts · SBOM · deploy to staging
release	e2e on staging · performance budgets · accessibility ·

DAST · manual approval · deploy to production ·
smoke tests · automatic rollback on failure

ACCEPTANCE CRITERIA

- ☐ All three repositories have CI running on every pull request, with required status checks that cannot be bypassed.
- ☐ A breaking API change fails provider contract verification before any client is affected; proven by a deliberate break.
- ☐ The end-to-end journey runs green against staging on every release candidate.
- ☐ An architecture test fails the build on a wall-clock read in presentation code.
- ☐ The suite is proven deterministic: 50 consecutive runs, at different times of day, all green.
- ☐ Coverage is measured and reported per repository, with agreed thresholds on domain logic specifically rather than on the codebase as an average.
- ☐ DORA metrics are collected: deployment frequency, lead time, change failure rate, restore time.

TAB 19 Release engineering and store delivery

Priority **P0** · Owner **MOBILE** OPS · Depends on TAB 18 · Closes M-04, M-06, G6

COMMAND

Establish signed, reproducible, attributable releases for all three tiers: production signing keys held securely, versioning consistent across repositories, app store listings and privacy declarations prepared, staged rollout with a kill switch, and a forced-update mechanism for the day a security fix cannot be optional.

Android release builds are currently signed with the debug key. `android/app/build.gradle` carries the generated placeholder and its TODO. A debug-signed build cannot be published, and more importantly a key established late cannot be changed later without every user reinstalling. This is resolved before any distribution, including internal pilot distribution.

SCOPE

Area	Requirement
Signing	Android upload and app-signing keys under Play App Signing; iOS distribution certificates and provisioning profiles. Keys in a secret manager or hardware-backed store, never in the repository, with documented custody, rotation, and recovery. Losing the signing key ends the app's identity — treat custody as seriously as a database backup.
Identifiers	Confirm final bundle identifiers. Current values (<code>com.ebpco.ebpco_user_app</code> / <code>com.ebpco.ebpcoUserApp</code>) are development placeholders and should reflect the owning LGU or agency. Identifiers cannot be changed after publication without losing the listing.
Versioning	SemVer, mapped to platform version codes, derived from tags rather than hand-edited. Build metadata (commit SHA, build time, environment) surfaced in-app for support — the About screen's <code>backendDescription</code> is the right idea; extend it.
Store listings	Descriptions, screenshots at required sizes, and the accounts to publish under. Government publisher accounts often require organisational verification — start early; it is a common cause of launch slippage.
Privacy declarations	Google Play Data Safety and Apple Privacy Nutrition Labels, plus iOS privacy manifests for the app and its SDKs. These must match TAB 20's processing record exactly; a discrepancy is both a store rejection and a privacy misstatement.
Permission justification	Camera, photo library and storage permissions must be justified in-app before the prompt and in the listing. The manifest already scopes <code>READ_EXTERNAL_STORAGE</code> to API ≤32 with <code>READ_MEDIA_IMAGES</code> above it — keep that discipline as target SDK rises.
Rollout and kill switch	Staged rollout with monitored crash and error rates and defined halt criteria. A server-side kill switch for a broken client version, and a forced-update path for security fixes.
Repository hygiene	Create the remote and publish <code>main</code> (M-04). Remove or relocate the stray <code>flutter_0*.png</code> artefacts at the repo root (M-06). Resolve the pending iOS <code>project.pbxproj</code> and SwiftPM working-tree changes rather than carrying them into a release.

ACCEPTANCE CRITERIA

- ❑ Release builds are signed with production keys; no debug-signed artefact can be produced by the release pipeline.
- ❑ Signing key custody, rotation and recovery are documented, and recovery has been rehearsed.
- ❑ Version numbers derive from tags and are identical in the artefact, the About screen, and `/version`.
- ❑ Store privacy declarations reconcile line by line with the TAB 20 processing record.
- ❑ A staged rollout can be halted and rolled back; rehearsed on a pre-release track.

- ☐ The kill switch is proven to disable an obsolete client version against staging.
- ☐ A forced update is proven to block use of an outdated version without data loss.
- ☐ Repository root is free of stray artefacts and the working tree is clean at the release tag.

TAB 20 Data privacy compliance (RA 10173)

Priority **P0** · Owner **GOVERNANCE** **BACKEND** · Start during Phase A · Closes M-03, M-15, M-16, G11

COMMAND

Complete Data Privacy Act compliance: appoint and publish a Data Protection Officer, register the data processing system with the National Privacy Commission, conduct a Privacy Impact Assessment, publish a counsel-reviewed privacy notice, enforce a retention schedule, and make every data subject right exercisable in the product rather than by email.

This is a legal precondition, not a launch task. Processing real applicant personal data without a registered processing system, a designated DPO, and a lawful basis exposes the LGU to NPC enforcement. It must be complete before the first real record, not before general availability.

SCOPE

Deliverable	Detail
DPO	Designated, trained, registered with the NPC, and contactable from inside the app . The Privacy & Data screen currently names the role without contact details (M-16); an unreachable DPO does not discharge the obligation.
Registration	Register the data processing system with the NPC per its current requirements for government agencies.
Privacy Impact Assessment	Full PIA covering collection, storage, transfer, retention and disposal across all three tiers and every third-party processor. Reviewed when the architecture changes.
Records of processing	Generated from the column-level personal data tags in TAB 04, so the record and the system cannot drift. Each field mapped to purpose, lawful basis, retention period and recipients.
Privacy notice	Plain-language, layered, in every offered language, reviewed by counsel (M-03). The app already ships a plain-language disclosure — that is the draft, not the approved text.
Consent	The existing consent gate before first document capture, with a recorded timestamp and withdrawal, is the correct pattern. Extend it to every processing activity relying on consent, and be clear where the basis is legal obligation rather than consent — consent that cannot be refused is not consent.
Data subject rights	Access, correction, erasure, portability, objection — each exercisable in-product with a defined response time. Erasure must reconcile with statutory retention: where the LGU must retain, say so and say why.
Retention schedule	Per data category, agreed and enforced by the TAB 06 job. Decision E-6, currently open as M-15.
Processor agreements	Data sharing or outsourcing agreements with every processor — hosting, push, crash reporting, scanning — before any of them touches personal data.
Breach procedure	The 72-hour notification path in TAB 15, rehearsed, with named responsibilities.

ACCEPTANCE CRITERIA

- ☐ DPO appointed, registered, and reachable from the app with a monitored channel.
- ☐ Processing system registered with the NPC; registration evidence filed.
- ☐ PIA completed, reviewed, and its actions closed or accepted in writing.
- ☐ Records of processing generated from the schema and reconciled with store privacy declarations.

- ☐ Privacy notice reviewed by counsel and published in every offered language.
- ☐ Each data subject right demonstrably exercisable end to end within its stated response time.
- ☐ Retention job proven to delete on schedule, with an audit record per deletion.
- ☐ A signed agreement is in place with every processor before it receives personal data.

TAB 21 Go-live: cutover and readiness review

Priority **P0** · Owner **OPS** **BACKEND** · Depends on all TABs

COMMAND

Run the production readiness review, complete operational documentation and LGU training, rehearse disaster recovery, execute a piloted cutover with a defined rollback, and hold a hypercare period with explicit exit criteria before declaring general availability.

PRODUCTION READINESS REVIEW

A structured gate, scored against ISO/IEC 25010 quality characteristics. Each line is evidenced or the launch does not proceed.

Dimension	Evidence required
Functional suitability	End-to-end journey green on production-shaped staging; every TAB's acceptance criteria signed off.
Reliability	SLOs defined and met during soak; backup restore rehearsed and timed; failover tested.
Security	Penetration test closed with no open high or critical finding; ASVS L2 and MASVS evidence complete.
Performance	Load, spike and soak results within budget; capacity plan accepted.
Usability & accessibility	WCAG 2.2 AA verified; assistive-technology journey completed; usability testing with real applicants, including low-digital-literacy participants.
Maintainability	CI green across three repositories; runbooks written; on-call staffed; dependency currency policy in force.
Compliance	NPC registration, DPO, PIA, privacy notice, retention schedule, processor agreements all complete.
Operability	Dashboards, alerts and runbooks in place; at least one drill executed per severity level.

CUTOVER

Stage	Detail
Data migration	If historical applications exist, migrate them with a rehearsed, reversible, validated procedure and a reconciliation report. If none exist, record that explicitly — an unstated assumption here is a discovery on go-live day.
Pilot	A limited cohort of real applicants and a single LGU office, with heightened monitoring and a direct feedback channel. Defined success criteria and a defined abort condition.
Parallel running	Where a counter or legacy process exists, run both until the pilot's success criteria are met. Do not remove the fallback before the replacement has proven itself under real load.
Rollback plan	Written, rehearsed, with a decision owner and a time limit on deliberation. Rollback that requires improvisation is not a rollback.
Hypercare	A defined period of elevated support with daily review and published exit criteria. General availability is declared on those criteria, not on a date.

DOCUMENTATION AND TRAINING

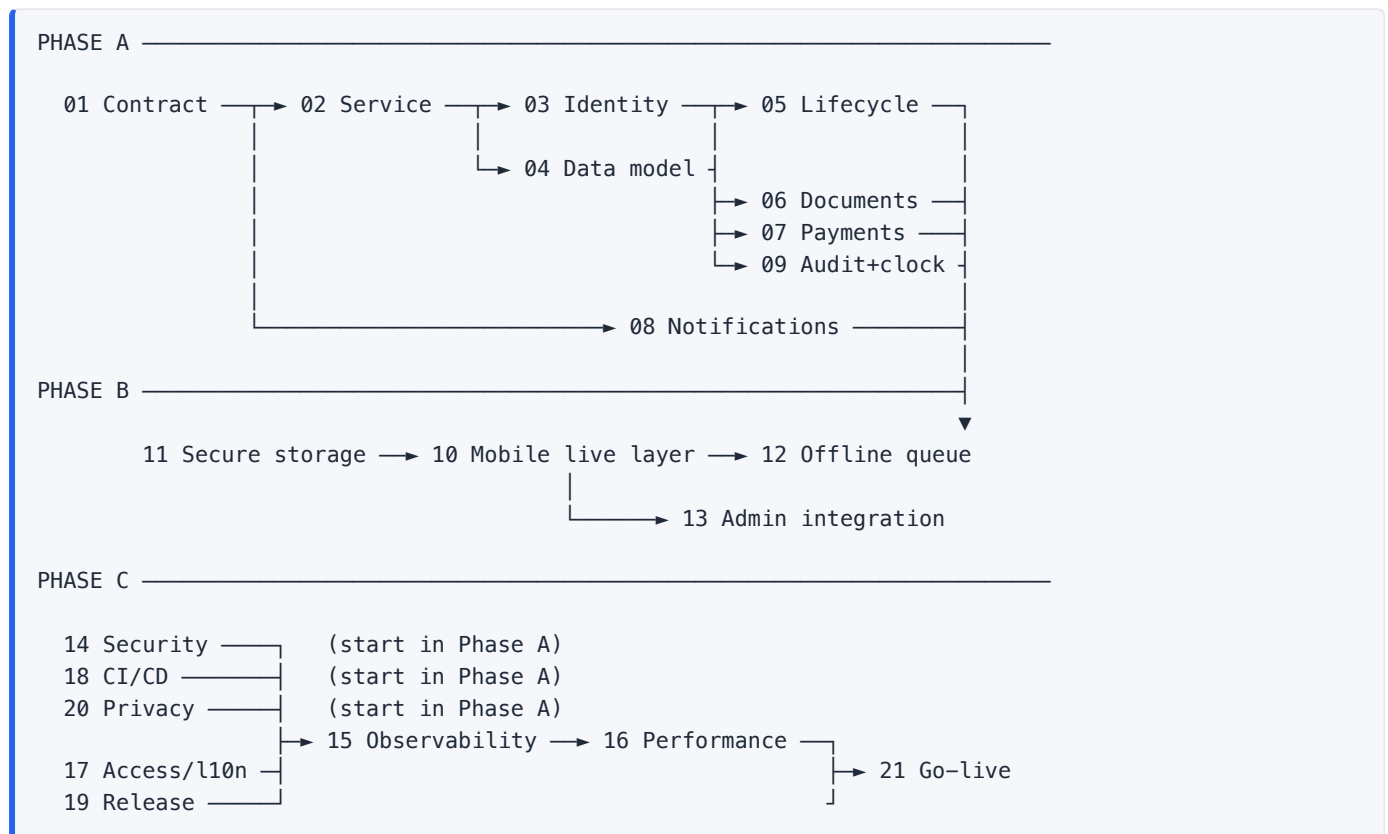
- Operations:** runbooks per alert, deployment and rollback procedures, backup and restore, incident and breach response, on-call handbook.

- **LGU staff:** role-based training for officers, evaluators, cashiers and administrators, with materials the LGU can re-run for new staff without the vendor.
- **Applicants:** in-app help, a public FAQ, and a support channel with a published response time. The Help screen exists; connect it to a staffed channel.
- **Handover:** architecture documentation, the contract, decision records, and a maintenance plan — so the LGU is not dependent on the original team's memory.

ACCEPTANCE CRITERIA

- ☐ Readiness review completed with every dimension evidenced and signed by a named owner.
- ☐ Disaster recovery drill executed; measured recovery time and recovery point within agreed objectives.
- ☐ Rollback rehearsed successfully on production-shaped infrastructure.
- ☐ Pilot completed against its success criteria, with findings closed or accepted.
- ☐ LGU staff trained and independently able to operate the system.
- ☐ Support channel live and staffed with a published response time.
- ☐ Hypercare exit criteria met before general availability is declared.

D Dependency map and critical path



CRITICAL PATH

01 → 02 → 03 → 04 → 05 → 10 → 13 → 21. Everything else can be parallelised with enough people, but nothing shortens this chain. TAB 01 is the constraint on the entire programme: until the contract is ratified, backend, mobile and admin work all proceed on assumptions, and any one of them being wrong invalidates work in the other two.

SEQUENCING ADVICE

- **Start 14, 18 and 20 in week one** alongside TAB 01. Security, CI and privacy are design inputs; retrofitting any of them costs several times what building with them costs.
- **Do TAB 11 before TAB 03 ships tokens.** Fixing token storage after real tokens are issued means every issued token was, for a period, stored insecurely.
- **Do not begin TAB 13 before TAB 05 is stable.** The admin is the heavier client and reworking it against a moving lifecycle engine is expensive.
- **Treat TAB 19's signing key as a week-one procurement item.** It is a dependency on people, not on code, and those have the longest lead times.

E Decisions the owner must make

These are not engineering choices and must not be made by whoever happens to reach them first. Each blocks the TAB named. Several are carried forward from the existing manual task register.

#	Decision	Blocks	What is actually being decided
E-1	Backend technology and hosting	TAB 02	Who operates this in five years. Choose for the team that will maintain it and for the LGU's procurement and data-residency constraints, not for the framework that benchmarks best.
E-2	Who owns and operates the service	TAB 21	LGU IT, a vendor under contract, or a shared regional service. Determines on-call, key custody, and what "handover" means.
E-3	Citizen's Charter data (M-08)	TABs 07, 09	Classification, pledged days, fee schedule and requirements per permit type. Must be supplied, never invented. The pledge clock and every fee are built on it.
E-4	May applicants cancel their own applications? (M-14)	TAB 05	A policy question with regulatory consequences, including what happens to fees already assessed or paid.
E-5	Identity proofing standard	TAB 03	Email verification, in-person verification, or PhilSys. Determines the legal weight of a filing under RA 8792 and the fraud exposure the LGU accepts.
E-6	Retention periods per data category (M-15)	TABs 06, 20	Balancing RA 10173 data minimisation against records retention obligations for permits. Needs counsel and the LGU records officer.
E-7	Accepted payment channels (M-09)	TAB 07	Bank Transfer and Onsite are implemented. Any e-wallet requires formal LGU acceptance and a regulated provider — offering an unaccepted channel would strand an applicant's money.
E-8	Partial payments permitted?	TAB 07	Changes the payment model and the lifecycle. Cheap to decide now, expensive to retrofit.
E-9	Escalation channel for statutory notices	TAB 08	Whether SMS or email backs up push for notices with legal consequence. A push notification to an uninstalled app reaches nobody, and the LGU may need to prove it gave notice.
E-10	Localisation scope (M-13)	TAB 17	Implement Filipino properly, or reduce the picker to English. The current display-only picker is the one option that should not survive.
E-11	Appointment booking (M-24)	TAB 05	QC e-Services treats a confirmed online appointment as the first basic requirement. If this LGU does too, it is in scope and affects the lifecycle.
E-12	Export format for payment records (M-25, M-26)	TAB 07	Clipboard CSV today. A printable receipt or a share sheet needs a plugin and a product decision about what applicants actually take to their accountant.
E-13	Repository visibility and remote	TAB 19	M-04 remains open: the mobile remote does not exist. Also decide public versus private, given the repositories will soon describe a live government system's attack surface.
E-14	Unified forms for field audit (M-10)	TAB 05	The DPWH/JMC Unified Building Permit and Occupancy forms, so the 16 wizards can be audited field-for-field against the legal instrument rather than against a reading of it.
E-15	Release logistics (M-11)	TAB 05	Claim location, office hours, and bring-with-you list. Small, and the last thing an applicant needs to be told correctly.

Fifteen open decisions is the real schedule risk. Most block a P0 TAB, and several (E-3, E-6, E-7) need people outside the engineering team. Convert each into a named owner and a date before Phase A starts. Engineering can proceed on stated assumptions in most cases, but every assumption that turns out wrong costs rework in the tier that built on it.

F Definition of done, for the programme

The programme is complete when all of the following are true at once.

- ☐ An applicant registers, files a permit application, attaches documents, receives an assessment, pays, and receives a permit — entirely through the mobile app, against the production backend.
- ☐ An LGU officer receives that application, verifies its documents, evaluates it, issues an Order of Payment, verifies payment, approves, generates and releases the permit — entirely through the web admin, against the same backend.
- ☐ Both applications display the same record, in their own vocabulary, from one authoritative source, with no client computing a status the server owns.
- ☐ Every action either party took is in a tamper-evident audit trail, attributable and timestamped.
- ☐ Processing time is measured against the LGU's published Citizen's Charter, with suspension while the applicant is responding, and is reportable to ARTA.
- ☐ An independent penetration test has been completed and no high or critical finding remains open.
- ☐ The system is registered with the NPC, has a reachable DPO, and every data subject right is exercisable in-product.
- ☐ Continuous integration runs on all three repositories and a contract break fails the build before it reaches a client.
- ☐ Service level objectives are published, monitored, and met; alerts have runbooks that have been used in a drill.
- ☐ A restore from backup and a rollback have both been rehearsed, timed, and recorded.
- ☐ The LGU can operate the system without the team that built it.

One measure above all others. The system is finished when an applicant who files a permit on their phone and an officer who decides it in the office are, demonstrably and auditably, looking at the same record. Everything in this document exists to make that sentence true.

Document control

Field	Value
Title	eBPCO — Production Launch Master Command
Issued	19 August 2026
Basis	Direct measurement of <code>eBPC0-Mobile-App</code> (Flutter) and <code>E-BPC0-Software-main</code> (Angular) working trees on the issue date; the existing Frontend Master Command; and the manual task register <code>docs/MANUAL-TASKS.md</code> .
Verified baseline	<code>flutter analyze</code> clean; <code>flutter test</code> 443 passed; 66 routes all reachable; no orphaned source files.
Structure	21 TABs across 3 phases; 15 owner decisions; 16 tracked gaps.
Supersedes	Nothing. Complements the Frontend Master Command, which remains authoritative for applicant-facing behaviour.
Review	At each phase boundary, and whenever an owner decision in section E is resolved.